ISO/IEC 27002:2013

Information security controls in practice

What the standard provides and how company ABC can use it

Justin Martin
IT490 Capstone October 18, 2026
Based on the assigned 2013 edition

14 clauses

35 categories

114 controls

What ISO 27002 provides

An international code of practice for selecting, implementing and managing information security controls.



Confidentiality

Limit information access to authorized people.



Integrity

Protect information against improper changes.



Availability

Keep information and services accessible when needed.

Source: ISO/IEC 27002:2013, Introduction and Clause 1

ISO 27001 and ISO 27002

ISO 27001

Requirements

Specifies requirements for an information security management system (ISMS).

Organizations can seek certification against these requirements.

ISO 27002

Guidance

Provides control guidance that supports the management system.

Organizations use it to develop and improve their own security practices.

ISO 27002 itself is guidance and does not provide organizational certification.

Sources: ISO/IEC 27002:2013, Introduction and Clause 1; ISO official 27002 overview

The structure of the 2013 edition

14
Security control clauses

35
Main security categories

114
Individual controls

Each control entry explains

- **The intended control**
- **Implementation guidance**
- **Other information that helps apply it**

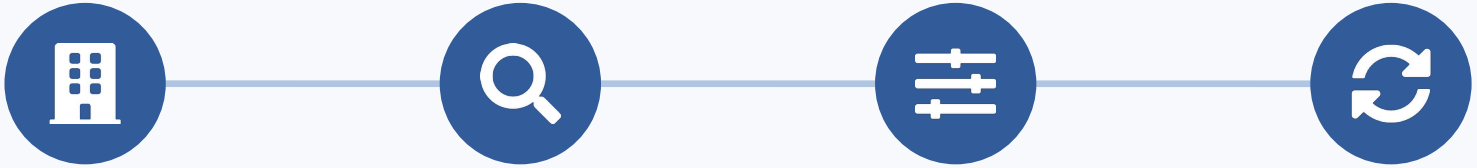
Source: ISO/IEC 27002:2013, Clauses 4.1 and 4.2

The 14 control areas

5	Information security policies
6	Organization of information security
7	Human resource security
8	Asset management
9	Access control
10	Cryptography
11	Physical and environmental security
12	Operations security
13	Communications security
14	System acquisition, development and maintenance
15	Supplier relationships
16	Information security incident management
17	Information security aspects of business continuity management
18	Compliance

Source: ISO/IEC 27002:2013, Clauses 5 through 18

Control selection starts with risk



01 Understand the business

Identify important information, systems and the consequences of losing them.

02 Assess requirements

Consider threats, vulnerabilities, business needs and legal or contractual duties.

03 Select controls

Choose safeguards that address the risks. Add organization specific controls where needed.

04 Review decisions

Document priorities and accepted risks. Reassess controls as the business changes.

Source: ISO/IEC 27002:2013, Introduction 0.2 through 0.5

Applying the guidance at company ABC

Sensitive information

Inventory customer records, assign owners and define handling rules.

8.1, 8.2

Administrator access

Approve privileged access and review who still needs it.

9.2.3, 9.2.5

Service disruption

Maintain backups and test restoration against business needs.

12.3.1

Security incidents

Assign response roles and practice reporting and escalation.

16.1.1, 16.1.2, 16.1.5

Illustrative application based on ISO/IEC 27002:2013, Clauses 8, 9, 12 and 16

Firewall rules and communications security

13.1.1

Network controls

ABC permits approved traffic and documents the business reason for each firewall rule.

13.1.2

Network services

ABC specifies security requirements and responsibilities for its network providers.

13.1.3

Segregation

ABC separates user systems, servers and network management according to risk.

Change approval and event logging support rule maintenance.
These are ABC implementation examples, not prescribed firewall commands.

Source: ISO/IEC 27002:2013, Controls 13.1.1, 13.1.2, 13.1.3, 12.1.2 and 12.4.1

Ownership and rollout



Management

Approves policy, resources and decisions about risk acceptance.



Information owners

Identify the information that needs protection and approve appropriate access.



IT and security teams

Compare current practices with selected controls, assign actions and implement changes.



Employees and suppliers

Follow the relevant procedures and report concerns through agreed channels.

Illustrative rollout based on ISO/IEC 27002:2013, Clauses 5, 6 and Introduction 0.3

Evidence that controls work

Access reviews

Retain approvals and evidence of removing unnecessary privileges.

9.2.5

Backup testing

Record restoration results and resolve failures.

12.3.1

Network validation

Test permitted and blocked traffic. Review logs and configuration changes.

12.4.1

Management follow up

Track unresolved findings, assign owners and check completion.

18.2.3

Illustrative evidence based on ISO/IEC 27002:2013, Controls 9.2.5, 12.3.1, 12.4.1 and 18.2.3

Questions the standard helps answer

Q

Must ABC use all 114?

Selection depends on risk and requirements. Some controls may not apply, and additional ones may be necessary.

Q

Does it guarantee security?

Controls need implementation, testing and regular review. The guidance cannot eliminate every risk.

Q

Can ABC certify to 27002?

Organizational ISMS certification is against ISO 27001. ISO 27002 supplies supporting control guidance.

For ABC, the value is a consistent basis for security decisions and evidence that safeguards work.

Sources: ISO/IEC 27002:2013, Introduction 0.3 and 0.4; ISO official 27002 overview

References and edition context

International Organization for Standardization. (2013). *Information technology — Security techniques — Code of practice for information security controls* (ISO/IEC Standard No. 27002:2013, 2nd ed.). Assigned course PDF.

International Organization for Standardization. (n.d.-a). *ISO/IEC 27002:2013*. https://www.iso.org/standard/54533.html

International Organization for Standardization. (n.d.-b). *ISO/IEC 27002:2022*. https://www.iso.org/standard/75652.html

Edition context
ISO replaced the 2013 edition with the 2022 edition. This presentation uses the assigned 2013 structure and control numbers. Clause references appear on the relevant slides.